

Computer Security Exam

Professors M. Carminati & S. Zanero

Milan, 26/01/2021

Last (family) Name _____

First (given) Name _____

Matricola or Codice Persona _____

Have you done any challenges/homework, even partially?	☐ Yes	☐ No
Professor:	☐ Carminati	☐ Zanero
Course:	☐ Milan	☐ Como

Instructions

Instructions:

- Duration: 2 hours.
- The exam is "open book". The students will be allowed to consult only the course material and notes. Be aware that notes and course materials will be accepted only in PDF or digital form, no extra paper or devices (e.g., phones, iPad) is allowed.
- You are not allowed to communicate with other students in any communication form. You will be expelled if, at any time, you do not follow this rule and will not be allowed to take the next session.
- Schemes are good, short answers are recommended.
- Always motivate your answer.
- If your final grade is below 120 (not considering the challenges), you will not be allowed to take the next exam call (even in the next session).
- At the discretion of the professor:
 - Any student may be required to sustain a subsequent oral exam only to confirm the evaluation of the written exams.
 - If you disable the screen sharing or the audio, you will be expelled and not allowed to take the next exam call.

PLEASE, USE THE FORMATTING SPECIFIED IN THE QUESTION

READ CAREFULLY ALL THE POINTS OF EACH QUESTION BEFORE WRITING YOUR ANSWER

Exercise 1 (130 points)

```
01 #include <stdio.h>
02 #include <stdlib.h>
03 #include <string.h>
04 #include <stdint.h>
05 #include <time.h>
06
07 typedef struct {
08     int logged;
09     char user[8];
10     char realuser[8];
11     char pass[8];
12     char realpass[8];
13 } data_t;
14
15 int login(data_t* data) {
16     int *fd;
17
18     fd = fopen("pass.txt", "r");
19     fscanf(fd, "%[^\n]", data->realpass);
20     fclose(fd);
21     fd = fopen("user.txt", "r");
22     fscanf(fd, "%[^\n]", data->realuser);
23     fclose(fd);
24
25     scanf ("%8s", data->pass);
26     scanf ("%s", data->user);
27
28     if(strncmp(data->pass, data->realpass, 8) == 0 && strncmp(data->user, data->realuser, 8) == 0) {
29         printf("Welcome to Westview! %s\n", data->user);
30         return 1;
31     }
32     return 0;
33 }
34
35 void verify(data_t* data) {
36     char msg[64];
37
38     scanf ("%64s", msg);
39     printf("%s\n", msg);
40     if ((!strncmp(msg, "VISION", 6)) || (!strncmp(msg, "WANDA", 5))) {
41         printf(msg);
42     } else
43         abort();
44 }
45
46 void main(int argc, char** argv) {
47     data_t data;
48
49     data.logged = 0;
50     data.logged = login(&data);
51     if (data.logged){
52         verify(&data);
53     } else {
54         abort();
55     }
56 }
```

Assume that

- The C standard library is loaded at a known address during every execution of the program, and that the address of the function `system()` is `0xfee48da0`.
- Environment variables are located in the highest addresses.

[5 points] 08. The program is affected by a typical buffer overflow vulnerability. Specify the vulnerable line/s of code. If more than one line is affected, use the following format 01, 02,...,N.

26

[5 points] 09. Motivate the previous answer.

(see slides)

[5 points] 10. The program may be affected by a typical format string vulnerability. Specify the vulnerable line/s of code. If more than one line is affected, use the following format 01, 02,...,N.

41

[5 points] 11. Motivate the previous answer.

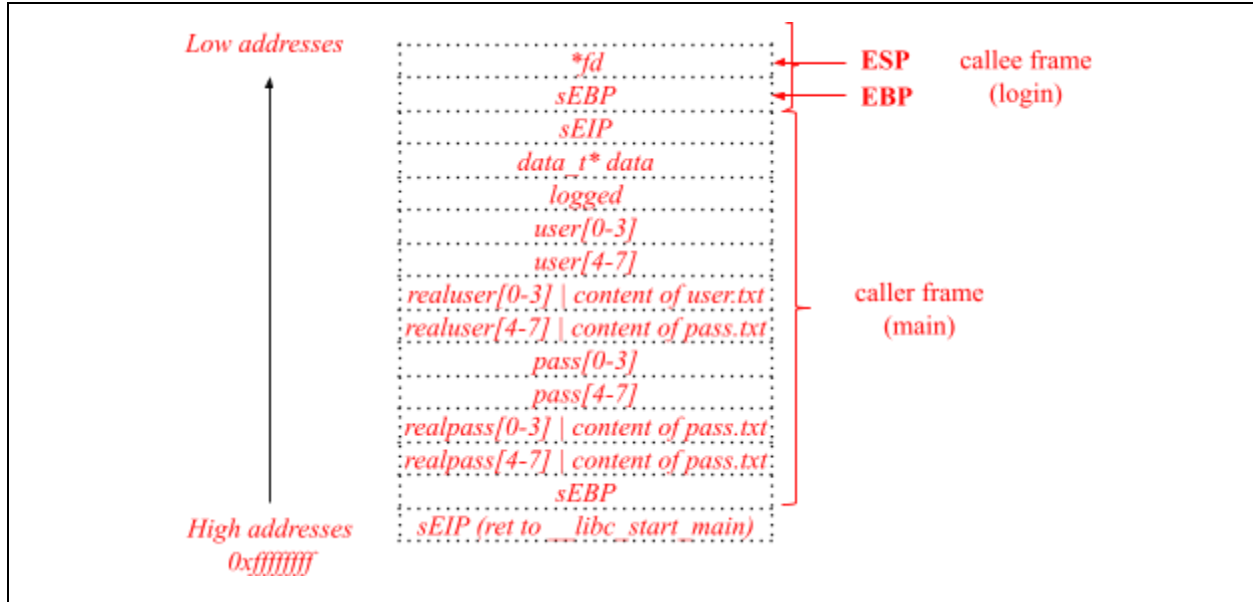
(see slides)

[5 points] 12. From now on, assume the program is compiled for the **x86 architecture** (32 bit) and for an environment that adopts the usual **cdec1** calling convention. Furthermore, assume that **no compiler-level or OS-level mitigations** against the exploitation of memory corruption errors is present (unless specified otherwise). Draw the stack layout after the program has executed the instruction at line 25, showing:

- Direction of growth and high-low addresses;
- The name of each allocated variable;
- The content of relevant registers (i.e., EBP, ESP);
- The functions stack frames.

Show also the content of the caller frame.

Use this format: [H] [var1 {main ()}] [var2 {main ()}] [sREG (EBP) {main ()}] [sREG1 {fun()}] [var (ESP) {fun()}] [L]

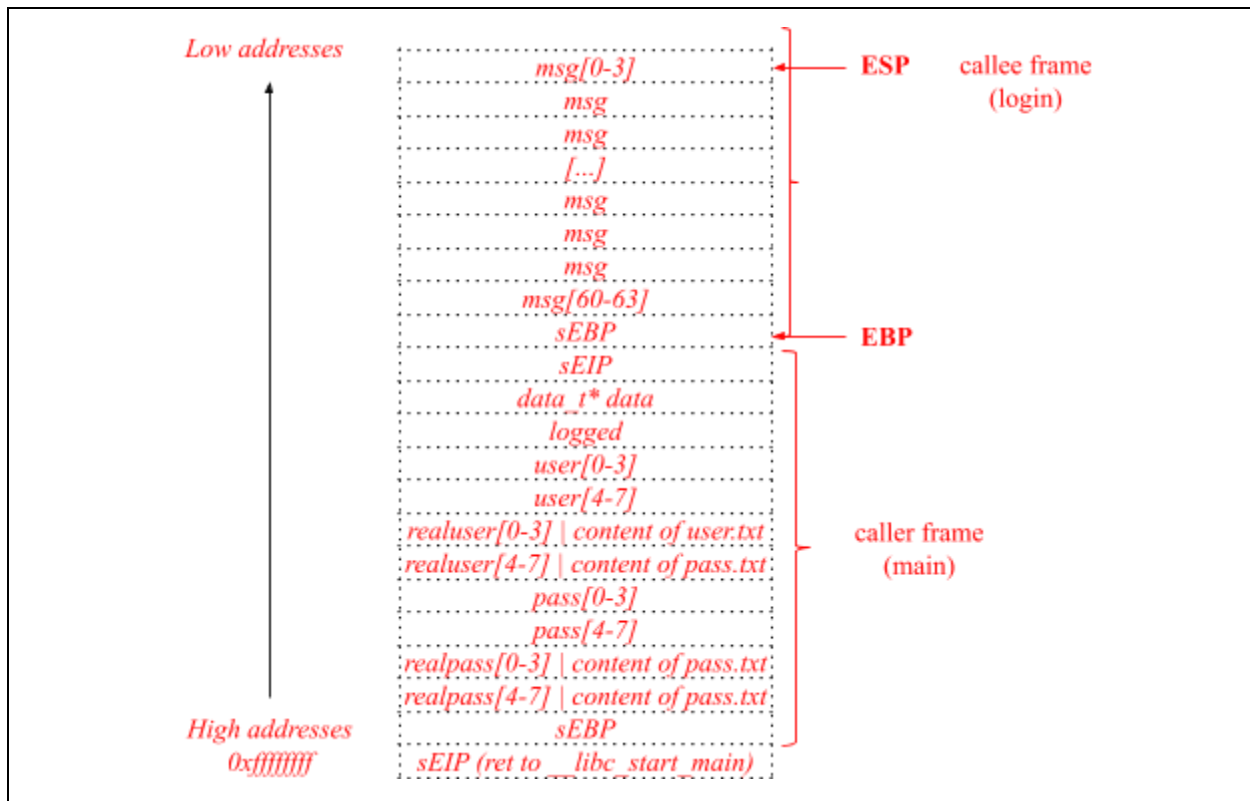


[5 points] 13. From now on, assume the program is compiled for the **x86 architecture** (32 bit) and for an environment that adopts the usual **cdec1** calling convention. Furthermore, assume that **no compiler-level or OS-level mitigations** against the exploitation of memory corruption errors is present (unless specified otherwise). Draw the stack layout after the program has executed the instruction at line 38, showing:

- Direction of growth and high-low addresses;
- The name of each allocated variable;
- The content of relevant registers (i.e., EBP, ESP);
- The functions stack frames.

Show also the content of the caller frame.

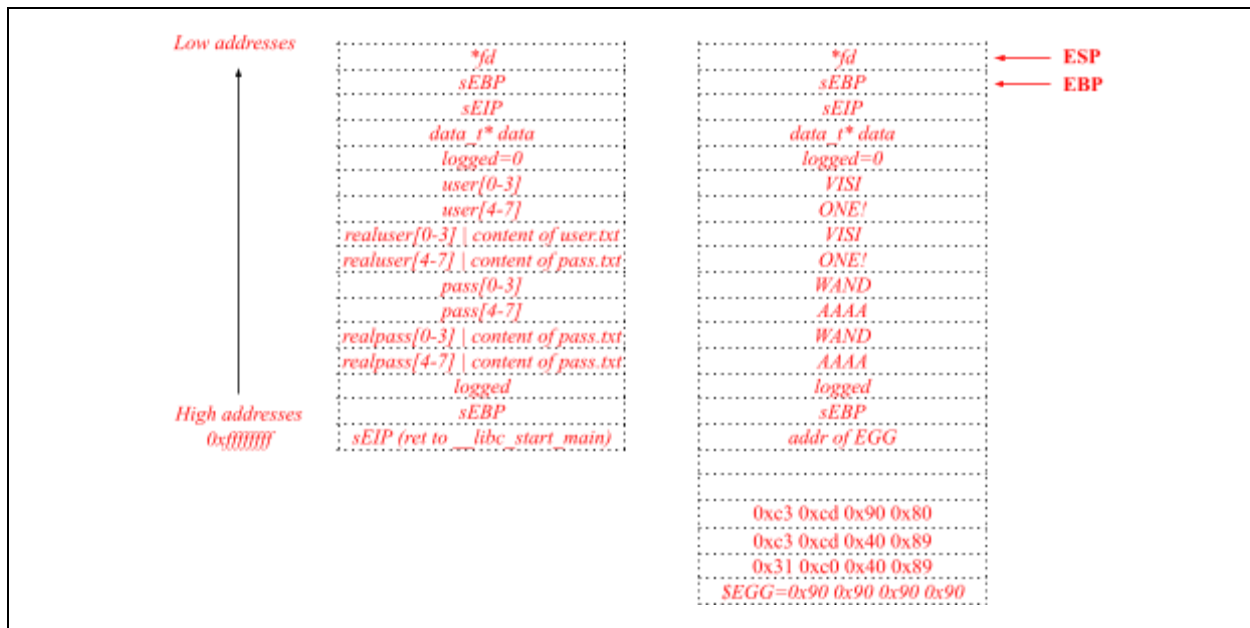
Use this format: [H] [var1 {main ()}] [var2 {main ()}] [sREG (EBP) {main ()}] [sREG1 {fun()}] [var (ESP) {fun()}] [L]



[10 points] 14. Focus only on the **stack-based buffer overflow(s)** you found at Point 1. Write an exploit for this vulnerability that bypasses the `verify_user()` function. Your exploit **must execute the following shellcode**, composed of 12 bytes, which open a shell: `0x31 0xc0 0x40 0x89 0xc3 0xcd 0x40 0x89 0xc3 0xcd 0x90 0x80`.

Make sure that you show how the exploit will appear in the process memory with respect to the stack layout right **before and after the execution of the vulnerable line** during the program exploitation. Ensure you describe **all the steps and assumptions** required for a successful exploitation of the vulnerability. Include also any assumption on how you must call the program (e.g., the values for the command-line arguments required to trigger the exploit correctly and/or environment variables, if any).

User (pass) and realuser (realpass) must be equal to pass the condition at line **Msg** must contain WANDA or VISION



[10 points] 15. Now focus on the format string vulnerability only. Write an exploit for this vulnerability that executes the previous shellcode, assuming that you have already allocated the shellcode in memory. Assume that:

- The address of the return address (*saved EIP*) of the function exploited is: **0xf4d0e2d3** (i.e., where to write)
- The address of the first instruction of the **shellcode** is at: **0xb5e2fd4f** (i.e., what to write)
- The displacement on the stack of the vulnerable function's argument is: **7**

Knowing that $\text{dec}(0xb5e2) = 46562$ and $\text{dec}(fd4f) = 64847$, write the exploit clearly, detailing all the components of the format string and all the steps that lead to a successful exploitation.

To exploit it, we need to write 0xb5e2fd4f to 0xf4d0e2d3. As 0xb5e2 < fd4f, we need to swap.

The general format string structure is:

<where to write+2><where to write>%<low value-bytes_already written>c%<pos>\$hn%<high value-lowvalue>c%<pos>\$hn

- Where to write = \xd3 \xe2 \xd0 \xf4
- Where to write + 2 = \xd5 \xe2 \xd0 \xf4
- We have already written WANDA OR VISION (5 or 6) + 8 characters but We need padding of (3 or 2) characters to fill 4 bytes cells. Hence, bytes_already written = 16
- low value = 0x49d0 -> 46562 - 16 = 46546
- high value - low value = 64847 - 46562 = **18285**

Also, the displacement on the stack of the printf's argument (i.e., the buffer message) is 7, the displacement of "where to write" is 7 + 2 = 9 and the displacement of "where to write + 1" is 10.

Complete exploit: \xd5\xe2\xd0\xf4\xd3\xe2\xd0\xf4%46546c\$9hn%18285c\$10hn

[5 points] **16.** Consider the correct implementation of “Stack Canary” mitigation technique. Is it effective to prevent your exploits at point 14.?

YES

[5 points] **17.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[5 points] **18.** Consider the “Stack Canary” mitigation technique. Is it effective to prevent your exploit at point 15.?

NO

[5 points] **19.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[5 points] **20.** Consider the “Address-space layout randomization (ASLR)” mitigation technique. Is it effective to prevent your exploits at point 13.?

YES

[5 points] **21.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[5 points] **22.** Consider the “Address-space layout randomization (ASLR)” mitigation technique. Is it effective to prevent your exploits at point 15.?

YES

[5 points] **23.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[5 points] **24.** Consider the “Non-executable stack (NX)” mitigation technique. Is it effective to prevent **your exploits** at point 13.?

YES

[5 points] **25.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[5 points] **26.** Consider the "Non-executable stack (NX)" mitigation technique. Is it effective to prevent your exploit at point 15.?

YES

[5 points] **27.** Consider the previous answer. If the mitigation technique is effective, explain why and describe how you would modify the exploit (or use a different exploitation technique) to bypass the mitigation. If it is not effective, please explain why.

(see slides)

[20 points] 28. Now assume that the stack is not executable and that the program is compiled with correctly implemented random stack canary (ASLR is not active). Is it still possible for the attacker to exploit the vulnerabilities you found in the code (your alternative solution does not necessarily require to execute the shellcode). Ensure you describe **all the steps and assumptions** required for a successful exploitation of the vulnerability. Include also any assumption on how you must call the program (e.g., the values for the command-line arguments required to trigger the exploit correctly and/or environment variables, if any).

With BO -> overwrite user/pass
With FO -> ret to libc

Exercise 2 (90 points)

“TellYourStory” is a website where users can tell their long stories and share them with friends. You must be logged in to see the stories of your friends, so you can comment!

The relevant pseudo-code of the web-app is the following:

01 <https://tellyourstory.org/readstory>

```
02 def read_story(request):
03     user = check_session(request.cookies['session'])
04     if user is None or request.method != "GET":
05         abort(403)
06     user_toread = request.args.get('user')
07     if not user_in_db(user_toread):
08         return render("Missing user. Couldn't read the story.")
09     page = request.args.get('page')
10     file = "."+user_toread+"/"+page
11     content = read_content_file(file)
12     page_to_render = "<h1> Story of " + user_toread + ", page " + page + " </h1>"
13     page_to_render += content
14     comments=retrieve_comments_to(user_toread)#reads the raw comments from the db
15     page_to_render += comments
16     return render(page_to_render)
17
```

18 <https://tellyourstory.org/adminsecrets>

```
19 def read_secret(request):
20     user = check_admin_session(request.cookies['session'])
21     if user is None or request.method != "GET":
22         abort(403)
23     content = read_content_file("./admin/secrets.txt")
24     return render(content)
25
```

26 <https://tellyourstory.org/insertcomment>

```
27 def insert_story():
28     user = check_session(request.cookies['session'])
29     if user is None or request.method != "POST" or not user_in_db(request.dest):
30         abort(403)
31     q = "insert into Comments (user, dest, text) values
32         ('"+user.username+"', '"+request.dest+"', '"+request.text+"');"
33     query(q)
34     return render("comment inserted")
35
```

36 <https://tellyourstory.org/deletecomments>

```
37 def delete_story():
38     user = check_session(request.cookies['session'])
39     if user is None or request.method != "GET":
40         abort(403)
41     q = "delete from Comments where user='"+user.username+"';"
42     query(q)
43     return render("comments deleted")
```

The website uses a relational database as a back-end. The database schema can be inferred from the following sample tables:

Users	
username	password
admin	4dm1n
Alex	AlwaysLate
Aron	password1
...	...

Comments			
Id	user	dest	text
0	Alex	Aron	I lo...
1	Alex	Aron	when...
2	Aron	Jess	You k...
...	...	...	...

Assume the following:

- usernames contain only alphanumeric characters, by registration policy.
- it is not possible to register a user twice (i.e., usernames are unique in the system) and all usernames contain at least one character.
- the function `user_in_db()` securely checks the database to be sure the user is present.
- the function `check_session()` securely manages the users' session; `check_admin_session()` securely manages the admin's session.
- the library used to access the DBMS does not support stacked queries, i.e., the DBMS does not execute multiple queries if asked on the same query and separated by a semicolon. For instance, the query "select x from y where a=b; update k set [...]" would trigger an error and not be executed.

Please read the following questions and then answer one by one.

[5 points] 29. Focus on SQL injection. Is there a vulnerability belonging to this class in the code?

Yes.

[5 points] 30. Motivate the previous answer: If the vulnerability is present, explain: -- (a) The vulnerable lines involved. -- (b) Why it is present. -- (c) How an adversary could exploit it. -- (d) The simplest procedure to remove this vulnerability while preserving the intended functionalities of the page. If the vulnerability is not present, explain why.

Lines: 31, 41 (if correctly argued, otherwise not present); see slides

[5 points] 31. Focus on Cross-site scripting (XSS). Is there a vulnerability belonging to this class in the code?

yes

[5 points] 32. Motivate the previous answer: If the vulnerability is present, explain: -- (a) The vulnerable lines involved. -- (b) Why it is present. -- (c) How an adversary could exploit it. -- (d) The simplest procedure to remove this vulnerability while preserving the intended functionalities of the page. If the vulnerability is not present, explain why. (please also specify which subclasses of XSS are present, e.g., stored/reflected/DOM-based)

Stored Xss; Lines : 31 (insert into db no whitelist, htmlentities etc.)+12(same as question above, line 41<)+13+14; see slides

+

[you need to motivate it] Reflected Xss; Lines 12 if there exists a file whose name is an XSS...

[5 points] 33. Focus on Cross site request forgery (CSRF). Is there a vulnerability belonging to this class in the code?

yes

[5 points] 34. Motivate the previous answer: If the vulnerability is present, explain: -- (a) The vulnerable lines involved. -- (b) Why it is present. -- (c) How an adversary could exploit it. -- (d) The simplest procedure to remove this vulnerability while preserving the intended functionalities of the page. If the vulnerability is not present, explain why.

All the functions have CSRF, there is no check that the user was using the website. See slides or old exams for the rest of the answer

[10 points] 35. Write an exploit to retrieve the current password of the user “admin”. Specify clearly all the steps and assumptions that are necessary to perform the attack correctly, including if the exploit needs interaction with the victim.

*Need to be logged in as your user “myuser”. Post to <https://tellyourstory.org/insertcomment>. You can use the field request.text of your POST to write the password of the admin on a comment to yourself. You later see your story and retrieve the password among the comments.
Request.text = '), ('myuser', 'myuser', (select password from Users where username='admin'))); --*

[10 points] 36. Write an exploit to delete the comments of your friend “Alex”, knowing he would never click on a url that contains the word delete. Do not leak his password as you know he would be seriously mad at you for that. Specify clearly all the steps and assumptions that are necessary to perform the attack correctly, including if the exploit needs interaction with the victim.

*Stored XSS in your own story or comment (the payload is the usual, see older exams); send a message to Alex with your story; He sees story; Steal his cookie; log in as Alex;
<https://tellyourstory.org/deletecomments>.
This works only if not HttpOnly.*

Alternatively, using URL shortner + CSRF or own website + CSRF

[20 points] 37. Assuming that the vulnerabilities that allowed logging-in as a different user have been solved(35, 36), and that the users have changed their password. Is there an exploit that you can think of to visualize the admin’s secrets? If this is the case, write the exploit and clearly specify all the steps and assumptions that are necessary to perform the attack correctly. If not, explain why.

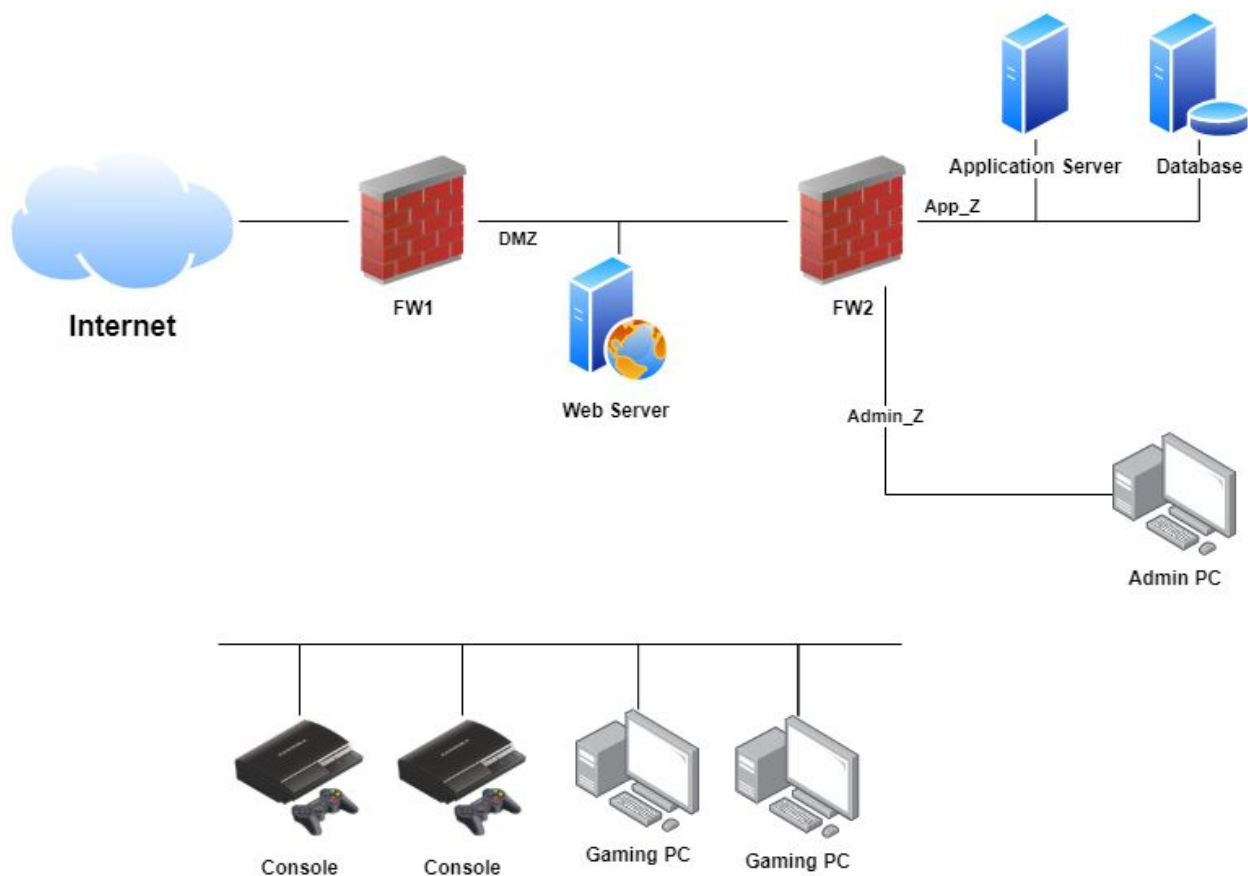
*Path traversal: <https://tellyourstory.org/readstory?user=Alex&page=../admin/secrets.txt>
The specified user must exists and you have to be logged in.*

[20 points] 38. Assuming that the vulnerabilities that allowed logging-in as a different user have been solved (35, 36), and that users have changed their password. How would you fix the problem of 37?

Line 10 is the problem: path traversal. Whitelisting page works fine.

Exercise 3 (70 points)

You have been contacted by a new Internet Cafè to setup their network. The Internet Cafè has a dining floor in which you can eat, drink a coffee and play board games, and another room in which you can play console and computer games. The Internet Cafè also has a website where you can book both a dining table and a console or a computer to play videogames. The owner of the Internet Cafè needs access from the Admin PC to the consoles and to the gaming PCs through the Remote Desktop Protocol on Port 3389. Furthermore, the owner needs to access the Internet (for browsing only), the webserver and the application server. The web server has to be accessible from the Internet, and it has to access the application server on an application-specific TCP port. In turn, the application server uses a database to store data. Finally, the consoles and gaming PCs have to access the Internet for browsing (https) and Gaming (You can assume a custom GAMING_PORT). Assume stateful packet filter multi-zone firewalls.



[10 points] 39. Your first task is to design the network layout to include the consoles and the gaming PCs. How would you modify the network layout presented in the figure to be compliant with the requirements described in the text? Justify your answer.

...

[20 points] 40. Complete the list of firewall rules shown below, according to your previous answer and the scenario described in the exercise.

Use the following format:

Firewall | Src IP:Src PORT | Direction of the 1st packet | Dst IP:Dst PORT | Policy | Description \\\

(example) FW1 | 10.0.0.1:ANY | zone 1 -> zone 2 | 192.168.0.2:443 | DENY | the X server in zone 1 cannot contact the Y server \\\

FW1 | ALL:ANY | ANY | ALL:ANY | DENY

FW2 | ALL:ANY | ANY | ALL:ANY | DENY

FW1 | ALL:ANY | Internet -> DMZ | WS:80/443 | ALLOW

FW2 | WS:-ANY | DMZ -> App_Z | AS_IP:TCP | ALLOW

FW2 | Admin_IP:ANY | Admin_Z->DMZ | ALL:ALL | ALLOW

FW2 | Admin_PC:ANY | Admin_Z -> App_Z | AS_IP:TCP | ALLOW

FW1 | Admin_IP:ANY | DMZ -> Internet | ALL:ALL | ALLOW

[10 points] 41. The owner wants to host an online tournament for a famous video game, FortNight. He wants to host the games on a private server placed in the DMZ. The server needs to be reachable (on port 1111) from the Internet, from the local gaming PCs, and from the admin PC. List any firewall rule needed to implement this change.

...

[10 points]. 42. While the tournament is ongoing players start experiencing packet loss and connection issues. You connect to FW1 to detect the problem. Here is a cut of the log from FW1 (assume the Game Server receives game-related data through a custom UDP packet, and answers with a similar one):

Sender	Receiver	Packet
131.75.244.24:8888	192.168.0.3:1111 (Game Server)	UDP req.
192.168.0.3:1111(GS)	131.75.244.24:8888	UDP resp.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.

192.168.0.3:1111(GS)	131.75.244.24:8888	UDP resp.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
154.24.123.12:8888	192.168.0.3:1111 (GS)	UDP req.
122.222.1.231:8888	192.168.0.3:1111 (GS)	UDP req.
[...]		
111.144.121.111:8888	192.168.0.3:1111 (GS)	UDP req.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
192.168.0.3:1111(GS)	131.75.244.24:8888	UDP resp.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
71.73.211.11:8888	192.168.0.3:1111 (GS)	UDP req.
133.23.1.232:8888	192.168.0.3:1111 (GS)	UDP req.
[...]		
99.12.244.121:8888	192.168.0.3:1111 (GS)	UDP req.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
131.75.244.24:8888	192.168.0.3:1111 (GS)	UDP req.
192.168.0.3:1111(GS)	131.75.244.24:8888	UDP resp.

Given the above packet capture, can you explain what is happening?

....

[5 points] 43. Given only the above packet capture, can you tell the IP address of the attacker?

IP address: it may be 131.75.244.24 but it can be spoofed

[5 points] 44. Given only the above packet capture, can you tell where the attacker is located ? Why?

An arbitrary Internet-connected network

[10 points]. Since you do not want to interrupt the tournament, is there a short-term mitigation you can put in place to solve the specific ongoing attack ? Is the solution you have just proposed still valid in general for the class of the attack?

*Block the attacker's IP, but it can be spoofed.
In general, no ...see slides...*

Exercise 4 (50 points)

Consider the following scenario: *One of the biggest hospitals in Wakanda, is hit by a ransomware attack (i.e., infected by malware with the sole purpose to encrypt all the files in the infected computer until the victim pays a ransom to the attacker). The ransomware is able to quickly propagate to all the computers in use by the hospital .*

[20 points] 46./47 What are the two most important risks in this scenario? Name and describe each of them, specifying the asset at risk and list one or two possible countermeasures.

Risk 1 Description: *Loss of privacy-critical data that can be exposed or permanently deleted*

Asset at risk: *Privacy-critical data*

Countermeasure: *Backups*

No countermeasure for exposure

Risk 2 Description: *Due to the fact that computers are not able to have access to data or perform analysis, people may die.*

Asset at risk: *Life and Wellness of Patients*

Countermeasure: *redundant systems, isolated systems, procedures for a fast disaster recovery,*

[10 point] 48. What is (or are) the possible threat agent(s) according to what you answered in (1.)?

The most likely threat agent is a cybercriminal motivated by the fact that the victim will pay a ransom, due to the value of the assets at risk.

[20 points] 49. Investigation of the ransomware infection found out the following: *"A doctor was browsing the Internet from a open public wireless network. In the meantime, he downloaded from the Internet a known Antivirus software from an unofficial store over HTTPS. After installing the antivirus he*

performed a full scan of the system, which found 235 terrible malware, and enabled automatic updates. A few hours later, he found all its files encrypted by the scary-looking ransomware. The day after, when he connected his laptop to the hospital network, he noticed that the ransomware started to propagate among the other computers in the company.”

a. Can you suspect what is going on (please state explicitly any assumptions you make)?

Trojan (Fake antivirus) + Worm (ransomware)

b. Can you suggest how to prevent this infection scenario in the future?

Avoid to download from unofficial website, check signature/hash + see slides